PENSE-BÊTE · RAPPORT ET STRATÉGIE

Rapport annuel sur la cybercriminalité 2025

03-60 COMCYBER-MI - Rapport annuel sur la cybercriminalité 2025 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le modèle Cybercrime-as-a-Service permet une spécialisation des tâches entre développeurs, courtiers et affiliés.
2. L'ingénierie sociale constitue le premier vecteur de compromission par la manipulation humaine.
3. Le cadre européen s'appuie sur la directive NIS2 et les règlements RIA (IA) et MiCA (crypto-actifs).

Écosystème et industrialisation de la menace

Notion	À retenir
Structuration du marché criminel	Modèle **Cybercrime-as-a-Service** : spécialisation des tâches (développeurs, courtiers en accès initiaux, affiliés) permettant à des acteurs peu compétents de mener des attaques complexes via des forums.
Infrastructures et communication	Usage de **forums spécialisés**, **messageries chiffrées** et **bulletproof hosting** (hébergement pare-balles) pour l'anonymat et la résilience face aux requêtes judiciaires.

Modes opératoires majeurs

Notion	À retenir
Ingénierie sociale et hameçonnage	Vecteur d'infection principal via manipulation humaine. Inclut **smishing** (SMS), **spoofing** téléphonique (numéro légitime affiché) et usage de l'**IA** pour des courriels crédibles.
Logiciels malveillants et attaques réseaux	Les **infostealers** exfiltrent des données d'identification. Les **rançongiciels** utilisent la **double ou triple extorsion** (chiffrement, menace de publication, déni de service). Les **botnets** servent au DDoS ou minage.
Vols et exploitation de données	Les données volées sont revendues sur des **forums** ou servent à l'**ingénierie sociale**. Les **administrations publiques** sont des cibles privilégiées et une part importante des fuites.

Nouvelles technologies et menaces hybrides

Notion	À retenir
IA au service du crime	**Deepfakes** (audio/vidéo) pour usurpation, **LLM** pour codes malveillants, **Deepfake-as-a-Service** et **data poisoning** (corruption des données d'apprentissage).
Usages illicites crypto-actifs	**Rançons** et **darknet** ; blanchiment via **mixeurs** ou **chain hopping** ; escroqueries (**faux investissements**, **fausses romances**) et **draineurs de portefeuilles** (contrats intelligents).
Menaces hybrides et physiques	**Extorsion violente** de crypto-actifs, **doxing** (divulgation d'infos privées menant à l'agression) et **sabotage physique** d'infrastructures (câbles, antennes).

Cadre juridique et jurisprudentiel

Notion	À retenir
Réglementations européennes	Directive **NIS2** (entités critiques/importantes) ; règlement **RIA** (IA par les risques, sanctions lourdes) ; règlement **MICA** (crypto-actifs, agrément prestataires).
Évolutions jurisprudentielles	CJUE : contrôle préalable par **autorité indépendante** (données téléphoniques) ; Cour de cassation : collecte **sources ouvertes** soumise au **cadre légal** et à la **loyauté**.

Opérations de démantèlement et affaires emblématiques

Notion	À retenir
Opérations de démantèlement	**Cronos** (infrastructure **LockBit**), **Endgame** (botnets **IcedID** et **Pikabot**), **Ghost** (messagerie chiffrée) et **Power Off** (plateformes **DDoS**).
Affaires emblématiques	**France Travail** (vol de données millions d'usagers), **Coco** (facilitation pédocriminalité/guet-apens) et **Epsilon** (infostealers, millions de données d'entreprises françaises).

IA et IoT : enjeux de défense et risques

Notion	À retenir
L'IA comme outil de défense	Stratégie **CapIA** (IA souveraine/éthique) ; projets **Authentik IA** (détection **deepfakes**) et **ODIP** (détection contenus pédopornographiques sans exposition visuelle).
Les risques liés à l'Internet des Objets	Multiplication des objets connectés augmentant la **surface d'attaque** ; risque d'enrôlement dans des **botnets** pour **attaques massives**.

Pièges et confusions

- ⚠ Confondre l'IA comme outil uniquement offensif alors qu'elle sert aussi les défenseurs pour la détection.
- ⚠ Croire que la cybercriminalité est isolée alors que les frontières avec la criminalité physique disparaissent.
- ⚠ Oublier que le facteur humain est le premier vecteur de compromission via l'ingénierie sociale.
- ⚠ Penser que la coopération internationale est optionnelle alors qu'elle est indispensable pour démanteler les infrastructures transnationales.
- ⚠ Ignorer que l'IA peut servir à la fois pour sophistiquer les fraudes et pour la détection.

Sigles et définitions

Affiliés	cybercriminels qui mènent des attaques en utilisant des outils fournis par des développeurs en échange d'une commission
Botnet	réseau de machines compromises connectées à Internet et pilotées à distance par des cybercriminels
CaaS	mise à disposition commerciale d'outils et de services cybercriminels clés en main
Credential Stuffing	technique automatisée testant des combinaisons d'identifiants volés pour accéder à des comptes
Deepfake	contenu multimédia falsifié par intelligence artificielle permettant d'usurper l'identité d'une personne
Infostealer	logiciel malveillant conçu pour dérober des données sensibles comme des mots de passe ou des cookies
Smishing	technique d'hameçonnage réalisée par l'envoi de SMS frauduleux
Vishing	escroquerie par hameçonnage vocal utilisant le téléphone pour manipuler la victime

Auto-test

1. Qu'est-ce que le Cybercrime-as-a-Service ?
2. Quel est le premier vecteur de compromission ?
3. Que désigne le terme 'bulletproof hosting' ?
4. Quelle directive concerne les entités critiques et importantes ?
5. Quelle opération a déstabilisé l'infrastructure du rançongiciel LockBit ?

Réponses : **1.** La mise à disposition commerciale d'outils et de services cybercriminels clés en main · **2.** Le facteur humain via l'ingénierie sociale · **3.** Des services d'hébergement tolérant les contenus illégaux et résistant aux demandes de fermeture · **4.** Directive NIS2 · **5.** L'opération Cronos.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.